

# 한 국 마 사 회 감 사 실

( 개선, 통보, 현지조치 )

일련번호 2025-IT-04  
분 야 개인정보보호  
제 목 개인정보 안전성 확보조치 이행 부적정  
소관본부 ▼부, ◀부  
소관부서 #부, ÷부, ×지사, ≠부  
내 용

## 1. 업무 개요

2025. 5. 우리 회는 개인정보처리시스템 접속기록 및 개인정보의 다운로드 상황에 대한 점검을 강화하기 위한 일환으로 대표 홈페이지의 “지사/문화센터” 메뉴를 통해 수집한 회원의 개인정보에 대한 접속일시 및 개인정보취급자, 업무명, 접근내역 등이 구체적으로 확인되도록 내부관리자 시스템을 개선하였다.

이에 따라 2025. 5.부터 관련부서들이 회원의 개인정보에 접근할 경우 개인정보처리시스템 접속일시 및 개인정보 취급자의 성명·IP, 접근내역이 자동으로 기록되며, 각 관련부서의 개인정보 취급자들이 개인정보를 다운로드하는 사유를 직접 기재하는 것만으로도 적절한 안전성 확보 조치가 가능해졌다.

## 2. 감사결과 확인된 문제점

### 가. 문화센터 회원 개인정보에 대한 안전성 확보 조치 이행 미흡

2025. 5.부터 2025. 11. 현재까지 관련부서들이 회원 개인정보에 접근한 내역 총

334 건을 살펴본 결과, 전체 내역의 69.2 %에 이르는 231 건에 대한 다운로드 사유가 “1”, “s”, “L”과 같이 의미 없는 문자열이나, “정보확인용”, “조회”와 같이 구체적인 목적을 파악할 수 없는 내용으로 작성되는 등 불성실하게 기재되고 있었다.

또한 관련부서들 중 일부부서가 내부관리자 시스템 접속 시 공용 ID를 사용함으로써, 회원의 개인정보를 다운로드 받은 개인정보취급자가 구체적으로 누구인지 여부를 특정할 수 없는 내역도 16 건이나 존재하였다.

그 결과 우리 회는 개인정보의 안전성 확보를 위한 적절한 시스템을 갖추었음에도 불구하고, 다운로드 사유의 불명확성이나 개인정보취급자의 불특정성 등으로 인해 적절한 점검 활동이나 사후 조치절차가 어려운 실정이었다.

#### **나. 개인정보 취급부서가 아닌 부서가 지나치게 장기간 개인정보 접근권한 보유**

문화센터 회원의 개인정보 취급부서인 ÷부는 개인정보보호지침 제18조에 따라 특정 부서가 업무상 필요로 회원의 개인정보를 취급하여야 할 경우 그 처리범위를 최소한으로 제한하는 조치를 취하여야 한다.

그런데 권한관리시스템 솔루션<sup>6)</sup>을 통해 지사/문화센터 내부관리자 시스템 접근권한을 점검하는 과정에서 # 부에 부여된 접근권한의 사용 목적이 한시적인 성격의 업무<sup>7)</sup>임에도 불구하고, 2025. 2. 13.부터 2027. 2. 13.까지 장기간 보유하고 있는 사실을 확인하였다.<sup>8)</sup>

이에 따라 # 부가 위와 같이 장기간 시스템 접근권한을 보유하게 된 경위를

---

6) IT인프라의 접근 제어, 계정 및 패스워드 관리, 보안 정책 준수를 통합적으로 지원하는 소프트웨어

7) 내부경영평가 실적 검증 등

8) 반면, 이와 대조적으로 EDMS의 경우에는 업무 성격에 따라 열람권한을 한시적으로 부여하여 보안정보에 대한 불필요한 접근 위험성을 최소화하고 있음

파악한 결과 아래와 같은 사실이 확인되었다.

2024. 3.경 문화센터 회원의 개인정보 취급부서인 ÷부는 #부의 내부관리자 시스템 접근권한 신청에 대해 보유기한을 별도로 정하지 않은 채 동의하였고(현재 ÷부 업무담당자들은 #부가 2027. 2.까지 회원 개인정보에 접근할 수 있는 상태에 있다는 사실조차 모르고 있는 상태로 확인됨), #부는 [사진 5]와 같이 접근권한 보유기간을 실제 업무에 필요한 범위를 초과하여 장기간으로 입력하면서 이와 같은 문제가 발생한 것으로 파악되었다.

이로 인해 지정된 개인정보 취급부서가 아닌 부서가 불필요하게 장기간 개인정보 접근권한을 보유하게 됨으로써 회원의 개인정보가 오·남용 등의 위험에 지속적으로 노출되고 있을 뿐만 아니라, 향후 실제 오·남용 등 사례가 발생하였을 때 그 구체적인 경위나 책임 소재 여부도 불분명한 실정이다.

실제 감사실에서 #부가 해당 시스템 접근권한을 통해 개인정보를 열람할 수 있는 구체적인 범위를 확인하기 위해 해당 권한을 똑같이 부여받아 시연해 보았으며, 이를 통해 [사진 6]과 같이 회원의 이름이나 나이, 전화번호 등 상당수의 개인정보들을 열람할 수 있는 상태임을 확인하였다.

따라서 개인정보 취급부서인 ÷부와 내부관리자 시스템 관리부서인 ≠부에 대해 개인정보 취급부서가 아닌 부서가 업무상 필요에 따라 개인정보를 처리하여야 할 경우 그 필요 한도 내에서 최소화할 수 있도록 해당 시스템의 체계를 개선하는 방안을 마련토록 요구해야 할 필요성이 있는 것으로 판단하였다.

## 조치할 사항

① [“가”항과 관련하여] ÷부 및 AA지사, BB지사, CC지사, DD지사, EE지사, FF

지사, GG지사, HH지사, II지사, JJ지사, KK지사, LL지사, MM지사, NN지사, OO지사, PP지사, QQ지사, RR지사, SS지사, TT지사, UU지사, VV지사, WW지사, XX지사, YY지사, ZZ지사는 앞으로 지사/문화센터 관련 내부관리자 시스템을 통해 고객의 개인정보를 다운로드 받을 경우 공용 ID의 사용을 원칙적으로 금지하고, 다운로드 사유를 구체적으로 기재하여 주시기 바랍니다.(현지조치)

② [“나”항과 관련하여] ÷부는 특정부서가 지사/문화센터 내부관리자 시스템 접근권한을 신청할 경우, 업무상의 이용 목적을 감안하여 이용 대상 및 범위, 기간 등을 최소한으로 제한하여 승인하시기 바랍니다.(통보)

③ [“나”항과 관련하여] ≠부는 지사/문화센터 내부관리자 시스템과 관련하여 특정부서가 업무상 필요로 접근권한을 요청할 경우 주요 개인정보 취급부서로부터 사전에 보유범위와 기간을 승인받을 수 있도록 시스템 체계를 개선하시기 바랍니다.(개선)

③ [“나”항과 관련하여] #부는 지사/문화센터 내부관리자 시스템에 대한 접근권한 필요성을 검토하고, 업무상 불가피하게 필요하다고 판단할 경우에는 문화센터 회원의 개인정보 열람 위험성을 최소화하시기 바랍니다.(현지조치)